

Vulnerability Assessment Report

- Target: <https://httpbin.org>

TASK-1

Prepared By: N. Sarvesh
Intern- Cyber Security
Internship

Executive Summary:

- A read-only vulnerability assessment was conducted on <https://httpbin.org> to identify common security weaknesses visible from publicly accessible resources.
- The assessment focused on HTTP security headers, exposed services, and publicly available configuration information. No exploitation, brute-force attacks, active scanning, or service disruption activities were performed.
- Several security header misconfigurations and information disclosure issues were identified. While no critical vulnerabilities were discovered, implementing the recommended controls would improve the overall security posture of the application.

Scope & Ethics:

Scope:

Public-facing website analysis only.

Activities Performed:

- Header Analysis
- Service Enumeration
- Configuration Review
- Passive Security Assessment

Activities Not Performed:

- Exploitation
- Brute Force Attacks
- Authentication Bypass
- Denial of Service
- Data Extraction

Tools Used:

- Nmap
- Chrome Developer Tools
- SecurityHeaders.com
- Canva
- GitHub

Risk Summary Table:

S.No	Finding	Risk Level	Business Impact
1.	Missing Content Security Policy (CSP)	High	Increased risk of malicious script execution
2.	Missing Strict-Transport-Security (HSTS)	Medium	HTTPS not enforced for future connections
3.	Missing X-Frame-Options	Medium	Possible clickjacking attacks
4.	Overly Permissive CORS Policy	Medium	Unauthorized cross-origin access risk
5.	Missing X-Content-Type-Options	Low	Browser may incorrectly interpret content types
6.	Missing Referrer-Policy	Low	Referrer information leakage
7.	Technology Information Disclosure	Low	Attackers gain information about server technologies
8.	Open Web Service Ports (80, 443)	Low	Publicly accessible services require monitoring

Finding 1: Missing Content Security Policy (CSP):

Risk: High

Evidence:

SecurityHeaders.com reported that the Content-Security-Policy header is missing.

Business Impact:

The website is more vulnerable to malicious script injection attacks. Attackers may be able to execute unauthorized scripts in a user's browser, potentially leading to data theft or website compromise.

Recommendation:

Implement a Content Security Policy (CSP) to restrict the sources from which scripts, styles, and other resources can be loaded.

Content-Security-Policy

[Content Security Policy](#) is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.

Finding 2: Missing Strict-Transport-Security (HSTS):

Risk: Medium

Evidence:

SecurityHeaders.com reported that the Strict-Transport-Security header is missing.

Business Impact:

The browser is not instructed to always use HTTPS connections. This may expose users to downgrade attacks or insecure communications if they accidentally access the website over HTTP.

Recommendation:

Enable the HSTS header to enforce HTTPS connections and improve communication security.

Strict-Transport-Security

[HTTP Strict Transport Security](#) is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; includeSubDomains".

Finding 3: Missing X-Frame-Options

Risk: Medium

Evidence:

SecurityHeaders.com reported that the X-Frame-Options header is missing.

Business Impact:

The website can potentially be embedded inside another website using an iframe. This may allow attackers to perform clickjacking attacks, tricking users into clicking unintended buttons or links.

Recommendation:

Configure the X-Frame-Options header to prevent unauthorized framing of the website.

X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
------------------------	--

Finding 4: Missing X-Content-Type-Options

Risk: Low

Evidence:

SecurityHeaders.com reported that the X-Content-Type-Options header is missing.

Business Impact:

Browsers may attempt to guess the content type of files instead of following the declared content type. This behavior could increase the risk of certain content interpretation attacks.

Recommendation:

Enable the X-Content-Type-Options header to prevent MIME-type sniffing by browsers.

X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
-------------------------------	---

Finding 5: Missing Referrer Policy:

Risk: Low

Evidence:

SecurityHeaders.com reported that the Referrer-Policy header is missing.

Business Impact:

The website does not control how much referral information is shared when users navigate to external websites. This may result in unnecessary exposure of URL information.

Recommendation:

Configure an appropriate Referrer-Policy header.

Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
------------------------	---

Finding 6: Missing Permissions Policy:

Risk: Low

Evidence:

SecurityHeaders.com reported that the Permissions-Policy header is missing.

Business Impact:

The website does not explicitly control access to browser features such as camera, microphone, geolocation, and other APIs.

Recommendation:

Implement a Permissions-Policy header to restrict unnecessary browser capabilities.

Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.
---------------------------	--

Finding 7: Information Disclosure:

Risk: Low

Evidence:

The response headers disclose server information:

server: gunicorn/19.9.0

Business Impact:

Exposing server technology information may help attackers identify software versions and research known vulnerabilities.

Recommendation:

Reduce unnecessary server banner information where possible.

Raw Headers	
HTTP/2	200
date	Thu, 11 Jun 2026 05:50:51 GMT
content-type	text/html; charset=utf-8
content-length	9593
server	gunicorn/19.9.0
access-control-allow-origin	*
access-control-allow-credentials	true

Finding 8: Open Ports

Risk: Low

Evidence:

Nmap identified the following open ports:

80/tcp open http

443/tcp open ssl/http

Business Impact:

These ports are necessary for web services, but all exposed services should be monitored and secured to reduce potential attack surfaces.

Recommendation:

Continue periodic port reviews and ensure unnecessary ports remain closed.

httpbin.org0.9.2

[Base URL: httpbin.org/]

A simple HTTP Request & Response Service.

Run locally: `$ docker run -p 80:80 kennethreitz/httpbin`

[the developer - Website](#)
[Send email to the developer](#)

Schemes		
HTTPS		
HTTP Methods	Testing different HTTP verbs	>
Auth	Auth methods	>
Status codes	Generates responses with given status code	>
Request inspection	Inspect the request data	>
Response inspection	Inspect the response data like caching and headers	>

Website Homepage

Raw Headers

HTTP/2	200
date	Thu, 11 Jun 2026 05:50:51 GMT
content-type	text/html; charset=utf-8
content-length	9593
server	unicorn/19.9.0
access-control-allow-origin	*
access-control-allow-credentials	true

Raw Headers

Security Headersby snyk

Scan your site now

Scan

Hide results

Follow redirects

Security Report Summary

F

Site:

https://httpbin.org/

IP Address:

64.197.124.68

Report Time:

11 Jun 2026 05:50:51 UTC

Headers:

Strict-Transport-Security

Content-Security-Policy

X-Frame-Options

X-Content-Type-Options

Referer-Policy

Permissions-Policy

Advanced:

Ouch, you should work on your security posture immediately.

Start Now

Missing Headers

Strict-Transport-Security

HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; includeSubDomains".

Content-Security-Policy

Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.

X-Frame-Options

X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".

X-Content-Type-Options

X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".

Referer-Policy

Referer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.

Permissions-Policy

Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

Raw Headers

HTTP/2

200

date

Thu, 11 Jun 2026 05:50:51 GMT

content-type

text/html; charset=utf-8

content-length

9593

server

unicorn/19.9.0

access-control-allow-origin

*

access-control-allow-credentials

true

Upcoming Headers

Cross-Origin-Embedder-Policy

Cross-Origin-Embedder Policy allows a site to prevent assets being loaded that do not grant permission to load them via CORS or CORP.

Cross-Origin-Opener-Policy

Cross-Origin-Opener Policy allows a site to opt-in to Cross-Origin Isolation in the browser.

Cross-Origin-Resource-Policy

Cross-Origin Resource Policy allows a resource owner to specify who can load the resource.

Additional Information

server

Server value has been changed. Typically you will see values like "Microsoft-OS/8.0" or "nginx 1.7.2".

access-control-allow-origin

This is a very lax CORS policy. Such a policy should only be used on a public CDN.

Security Headers

Conclusion:

The assessment identified several security hardening opportunities related to HTTP response headers and information disclosure. Addressing these findings will improve resilience against common web-based attacks and strengthen the website's overall security posture.

....THANK YOU....